

Module 10

Comprehending Security Compliance and Troubleshooting

Module Objectives

- Understand security compliance and regulation.
- Recognize and implement security best practices.
- Troubleshoot security issues.

Lesson 10.1

Aspects of Compliance and Regulation

Cloud+ CV0-004 Certification Exam Objective:

- 4.2 Compare and contrast aspects of compliance and regulation.

Aspects of Compliance and Regulation

- The Impact of Laws and Regulations
- Data Privacy and Protection
- Data Classification
- Data Retention Policies
- Industry Standards for Compliance and Regulation

The Impact of Laws and Regulations

- Regulated industries
- Legal concerns for cloud data
- Mitigation strategies

Data Privacy and Protection

- Data ownership
- Data residency
- Data sovereignty
- Data localization
- Data locality

Data Classification

- Purpose
- Classification schemes
- CSP tools
 - Amazon Macie
 - Microsoft Azure Information Protection
- Shared security model
- Troubleshooting misclassification

Data Retention Policies

- Recognize a litigation hold
- Recognize a contractual hold
- Recognize a regulatory hold

Industry Standards for Compliance and Regulation

- Systems and Organization Controls 2 (SOC2)
- Payment Card Industry Data Security Standards (PCI DSS)
- International Organization for Standardization (ISO) 27000 Standards
- Cloud Security Alliance

Lesson 10.2

Security Best Practices

Cloud+ CV0-004 Certification Exam Objective:

- 4.4 Given a scenario, apply security best practices.

Security Best Practices

- Principle of Least Privilege
- Zero Trust Cloud Security
- Benchmark Practices
- Hardening
- Security Patching
- Encryption
- Encrypting Data in Transit
- Encrypting Data at Rest
- Secrets Management
- Application Programming Interface Security
- Container Security
- File and Object Storage Security

Principle of Least Privilege

- Definition
- Example scenario
 - Limit logon hours
 - Limit read / write permissions
 - Limit print management rights
- Implementation
 - Authentication
 - Folder access
 - Printer access

Zero Trust Cloud Security

- Definition
- Key features
 - Granular access controls
 - Continuous authentication verification
 - Zero implicit trust
 - Dynamic security
- Implementation

Benchmark Practices

- Center for Internet Security (CIS)
 - Level 1
 - Level 2
- Vendor specific security benchmarks

Hardening

- Configuration baselines
- Automated configuration management
- Deactivate default accounts
- Change default settings
- Control remote access
- Understand the importance of logs
- Software security
- Antivirus and anti-malware

Security Patching

- Hotfixes
- Virtual patches on a web application firewall
- Signature updates
- Rollups
- Patch application

Encryption

- The goals of encryption
 - Confidentiality
 - Integrity
 - Non-repudiation
- Symmetric encryption
- Asymmetric encryption
- Hash cryptography

Encrypting Data in Transit

- Hypertext Transfer Protocol Secure (HTTPS)
- Transport Layer Security (TLS)
- IPsec network encryption

Encrypting Data at Rest

- Cloud encryption
- Drive and file encryption
- File Integrity Monitoring (FIM)

Secrets Management

- Definition
- AWS Secrets Manager
- Benefits
 - Prevent passwords and other secret credentials from being stored in code or configurations

Application Programming Interface Security

- Endpoints
- API gateways
- Security best practices
- Troubleshooting endpoints

Container Security

- Privileged container configuration
- Unprivileged container configuration
- File access permissions

File and Object Storage Security

- File storage
- Object storage
- Security best practices
 - Encryption
 - Encryption key management
 - Integrity testing
 - Access controls
 - IAM
 - Versioning
 - Data replication

Lesson 10.3

Troubleshooting Security Issues

Cloud+ CV0-004 Certification Exam Objective:

- 6.3 Given a scenario, troubleshoot security issues.

Troubleshooting Security Issues

- Authentication Issues
- Authorization Issues
- Network and Directory Security Groups
- Security Groups and Access Control Lists
- Network Access Control
- Software Vulnerability Issues
- Unauthorized Software
- Data Security Issues
- Lack of Encryption in Protocols
- Cipher Suite Deprecations

Authentication Issues

- Basic workstation authentication fails
- Multifactor authentication fails
- Cloud software or admin console access fails
- Leaked credentials

Authorization Issues

- Privilege escalation
- Unauthorized access
 - Cannot access SaaS resources
 - Cannot access PaaS resources
 - Cannot access IaaS resources

Network and Directory Security Groups

- Cannot access an instance
- Cannot access subnet
- Users cannot access a file or folder but should be able to

Security Groups and Access Control Lists

- Security groups
- Troubleshooting connectivity issues
 - No connectivity to instances
- Access control lists (ACLs)

Network Access Control

- NAC is not checking all devices
- NAC is not detecting unsecured devices

Software Vulnerability Issues

- Security audits discover software vulnerabilities
- Vendor has not resolved software vulnerabilities
- Vulnerabilities found in software developed in-house

Unauthorized Software

- Software audits, inventories, or configuration management tools detect unauthorized software
- Unauthorized software is detected on systems

Data Security Issues

- Unencrypted data
- Data breach
- Data misclassification

Lack of Encryption in Protocols

- Unencrypted protocols in use

Cipher Suite Deprecations

- Recommended cipher suites
- Deprecated cipher suites
- Troubleshooting
 - Network fails cipher suite security audit

Module Summary

- Data Identification and Classification: Know what data you have and where it is stored.
- Legal and Regulatory Compliance: Ensure storage locations and cloud service providers meet legal requirements.
- Business Process Compliance: Align business processes with recognized standards and best practices.